INFORME DE GESTIÓN DE INCIDENTES

DE SEGURIDAD DE LA INFORMACIÓN

Incidente: Explotación de vulnerabilidad de inyección SQL

en aplicación web DVWA alojada en servidor Debian

Marco de referencia: ISO/IEC 27001:2022

Controles aplicables: A.5.24, A.5.25, A.5.26, A.5.27, A.8.25, A.8.26, A.8.28

Clasificación: USO INTERNO — CONFIDENCIAL

Datos generales del incidente

ID del incidente	INC-2026-001
Fecha de detección	24 de abril de 2026
Fecha del informe	24 de abril de 2026
Responsable del informe	Vanessa Villagrana Velázquez
Tipo de incidente	Explotación de vulnerabilidad web — Inyección SQL (CWE-89)
Activo afectado	Aplicación web DVWA / Servidor Debian (entorno de laboratorio)
Criticidad	ALTA (en entorno productivo equivalente)
Estado	Contenido — Documentado con fines de simulación y formación
Entorno	Máquina virtual de pruebas controladas

1. Título del reporte

Informe de gestión del incidente de seguridad INC-2026-001: explotación controlada de una vulnerabilidad de inyección SQL (SQLi) en la aplicación web Damn Vulnerable Web Application (DVWA), desplegada sobre un servidor Debian en entorno virtualizado de laboratorio, elaborado conforme a los lineamientos de la norma ISO/IEC 27001:2022 y alineado con los procesos de gestión de incidentes del SGSI.

2. Introducción

El presente informe documenta el proceso de identificación, explotación y análisis de una vulnerabilidad de inyección SQL (SQL Injection) detectada en un entorno de pruebas controlado basado en la aplicación Damn Vulnerable Web Application (DVWA). Dicho entorno fue desplegado íntegramente desde cero sobre una máquina virtual con sistema operativo Debian, utilizando un stack LAMP (Linux, Apache, MariaDB y PHP) como infraestructura de soporte.

La inyección SQL es una de las vulnerabilidades más críticas según el proyecto OWASP Top 10 (categoría A03:2021 — Injection) y representa uno de los vectores de ataque con mayor impacto en la confidencialidad, integridad y disponibilidad de la información almacenada en bases de datos. Su explotación puede desembocar en exfiltración masiva de datos, manipulación de registros, escalada de privilegios e incluso ejecución remota de comandos sobre el servidor de base de datos.

Este documento tiene una doble finalidad: por un lado, servir como evidencia de la ejecución del ejercicio de simulación en un entorno de laboratorio con fines formativos y de concientización; por otro, establecer un modelo replicable de informe de gestión de incidentes alineado con los requisitos de la cláusula 5.24 a 5.28 de la norma ISO/IEC 27001:2022, relativos a la planificación, preparación, respuesta, evaluación y aprendizaje a partir de incidentes de seguridad de la información.

El alcance del informe incluye la descripción detallada del incidente simulado, la metodología de reproducción empleada, el análisis del impacto potencial que una vulnerabilidad equivalente podría generar en un entorno productivo real, y las recomendaciones técnicas y organizativas para su mitigación.

3. Descripción del incidente

Durante la ejecución de un ejercicio autorizado de evaluación de seguridad de aplicaciones web, se logró explotar con éxito una vulnerabilidad de inyección SQL presente en el módulo "SQL Injection" de la aplicación DVWA, configurada con el nivel de seguridad bajo (security level: low). El vector de ataque empleado consistió en la manipulación del parámetro de entrada User ID del formulario de consulta, mediante la inserción de una carga maliciosa que alteró la lógica original de la consulta SQL ejecutada por el backend.

3.1 Detalles técnicos

Vulnerabilidad	Inyección SQL (In-band / Error-based / Boolean-based)
Clasificación CWE	CWE-89 — Improper Neutralization of Special Elements used in an SQL Command
Categoría OWASP Top 10	A03:2021 — Injection
CVSS 3.1 (estimado)	9.8 — Crítica (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Vector de entrada	Campo User ID del formulario HTTP GET
Carga útil utilizada	1' OR '1'='1
Componente afectado	Módulo PHP de DVWA con consulta SQL concatenada sin sanitización
Motor de base de datos	MariaDB

3.2 Análisis del payload

La aplicación, al recibir el identificador de usuario en el parámetro correspondiente, construye una consulta SQL mediante concatenación directa de cadenas, sin parametrización ni saneamiento. La consulta original tiene una estructura similar a la siguiente:

```
SELECT first_name, last_name FROM users WHERE user_id = '$id';
```

Al introducir el valor 1' OR '1'='1 en el campo User ID, la consulta resultante que se ejecuta contra la base de datos se transforma en:

```
SELECT first_name, last_name FROM users WHERE user_id = '1' OR '1'='1';
```

La condición '1'='1' es tautológicamente verdadera, por lo que la cláusula WHERE se evalúa como verdadera para todas las filas de la tabla users. Como consecuencia, el motor de base de datos retorna la totalidad de los registros almacenados en dicha tabla, derivando en una exfiltración completa del conjunto de datos accesible desde el contexto de la consulta.

3.3 Evidencia del incidente

Tras el envío del payload, la aplicación devolvió en pantalla los registros de todos los usuarios almacenados en la base de datos de DVWA, en lugar de un único registro correspondiente al identificador solicitado. A continuación se muestra la captura de pantalla tomada durante la ejecución del ataque, que constituye la evidencia gráfica principal del incidente:

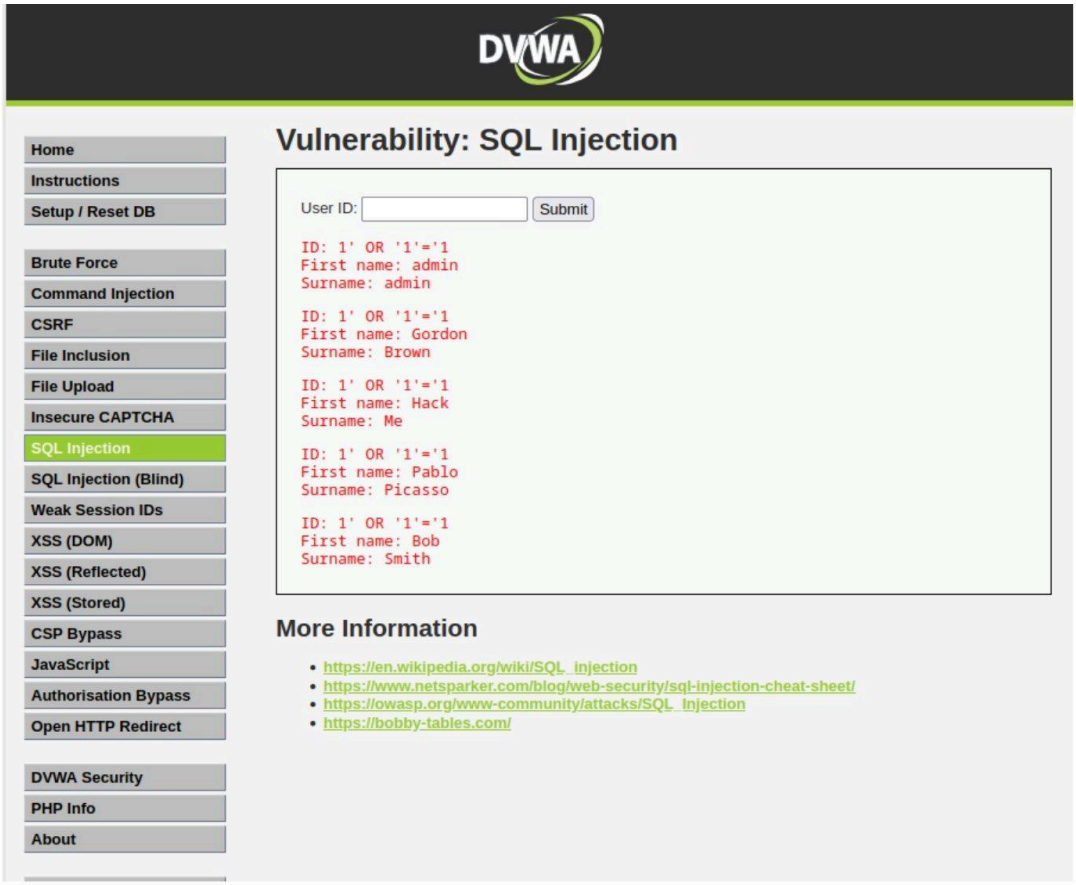

Figura 1. Respuesta de la aplicación DVWA tras la inyección del payload 1' OR '1'='1, mostrando la totalidad de los registros de la tabla users.

La evidencia recopilada muestra los siguientes datos extraídos de la tabla de usuarios:

ID	Nombre (First name)	Apellido (Surname)
1' OR '1'='1	admin	admin
1' OR '1'='1	Gordon	Brown
1' OR '1'='1	Hack	Me
1' OR '1'='1	Pablo	Picasso
1' OR '1'='1	Bob	Smith

La obtención de los cinco registros de la tabla de usuarios, incluido el registro del usuario administrador (admin), confirma la explotación exitosa de la vulnerabilidad y evidencia la ausencia total de controles de entrada, validación y consultas parametrizadas en el código fuente del módulo afectado.

4. Proceso de reproducción

A continuación se detalla el procedimiento paso a paso que permite reproducir el incidente en un entorno de laboratorio controlado. Este apartado cumple una función didáctica y forense, aportando trazabilidad completa de las acciones ejecutadas, conforme a las buenas prácticas de documentación de incidentes establecidas por ISO/IEC 27035.

4.1 Preparación del entorno

1. Despliegue de una máquina virtual utilizando software de virtualización (VirtualBox o VMware) con sistema operativo Debian instalado desde su imágen ISO oficial.
2. Actualización del sistema base mediante los comandos: sudo apt update && sudo apt upgrade.
3. Instalación del stack LAMP requerido por DVWA: servidor web Apache2, motor de base de datos MariaDB y lenguaje PHP junto con sus módulos (php-mysqli, php-gd).
4. Verificación del estado de los servicios: systemctl status apache2 y systemctl status mariadb.
5. Aseguramiento inicial de MariaDB mediante la ejecución de mysql_secure_installation.
6. Descarga del código fuente de DVWA desde su repositorio oficial en GitHub y despliegue en el directorio /var/www/html/.
7. Configuración del archivo config.inc.php de DVWA con las credenciales de la base de datos.
8. Creación de la base de datos y el usuario dedicado en MariaDB, asignando los permisos correspondientes.
9. Ajuste de permisos en los directorios de configuración y carga de archivos de la aplicación.
10. Acceso a la aplicación desde el navegador a través de la URL http://<IP-servidor>/DVWA/ y ejecución del proceso de inicialización desde el apartado Setup / Reset DB.
11. Autenticación en la aplicación con las credenciales por defecto (admin / password) y ajuste del nivel de seguridad a Low desde el apartado DVWA Security.

4.2 Ejecución del ataque

12. Navegación al módulo SQL Injection desde el menú lateral izquierdo de la aplicación.
13. Identificación del formulario de entrada con el campo User ID y el botón Submit.
14. Envío de un valor legítimo (por ejemplo, 1) para observar el comportamiento esperado de la aplicación, que devuelve un único registro correspondiente al identificador introducido.
15. Introducción del payload malicioso 1' OR '1'='1 en el campo User ID y ejecución del formulario mediante el botón Submit.
16. Observación de la respuesta del servidor, que retorna la totalidad de los registros existentes en la tabla users, confirmando la explotación exitosa de la vulnerabilidad.
17. Captura de evidencia mediante screenshot del resultado obtenido para su posterior inclusión en el expediente del incidente.

4.3 Payloads adicionales verificados

Durante el ejercicio se comprobó que otras variantes de payload producen resultados equivalentes o extienden las capacidades del ataque:

- 1' OR 1=1 # — Variante con comentario MySQL para anular cláusulas posteriores.
- 1' OR '1'='1' -- — Variante con comentario SQL estándar.
- 1' UNION SELECT user, password FROM users # — Ataque UNION-based para extraer credenciales.
- 1' AND 1=2 UNION SELECT database(), version() # — Enumeración de motor y base de datos.

5. Impacto del incidente

Aunque el incidente se ha ejecutado en un entorno aislado y con fines exclusivamente formativos, el análisis del impacto se realiza desde la perspectiva de un escenario productivo equivalente, con el objetivo de dimensionar correctamente la criticidad de la vulnerabilidad y justificar las medidas correctivas propuestas.

5.1 Afectación sobre la tríada CIA

Dimensión	Nivel	Justificación
Confidencialidad	**ALTO**	Exposición íntegra de la tabla de usuarios, incluidos datos identificativos y, potencialmente, credenciales almacenadas (hashes de contraseñas).
Integridad	**ALTO**	Posibilidad de escalada a UPDATE / INSERT / DELETE mediante stacked queries, permitiendo la manipulación o destrucción de registros.
Disponibilidad	**MEDIO**	Riesgo de degradación del servicio por consultas maliciosas masivas (time-based payloads) o por operaciones DROP sobre tablas o esquemas.

5.2 Impacto en un escenario productivo equivalente

- Impacto legal y regulatorio: posible incumplimiento del Reglamento General de Protección de Datos (RGPD / GDPR) y de la normativa local de protección de datos personales, con sanciones económicas de hasta el 4 % de la facturación anual global.
- Impacto reputacional: pérdida de confianza de clientes y socios comerciales, con coste reputacional difícil de cuantificar y prolongado en el tiempo.
- Impacto económico directo: costes de remediación, notificación obligatoria a las autoridades y a los titulares de los datos, auditorías forenses externas y potenciales indemnizaciones.
- Impacto operativo: necesidad de restauración de sistemas desde copias de seguridad, rotación obligatoria de credenciales y revisión integral del código fuente afectado.

- Riesgo de movimientos laterales: las credenciales extraídas pueden ser reutilizadas contra otros sistemas internos (password reuse), facilitando la escalada horizontal del ataque.

5.3 Riesgo residual identificado

La vulnerabilidad explotada es de nivel CRÍTICO y, en un entorno real, debería escalarse de forma inmediata al Comité de Seguridad de la Información para su tratamiento prioritario, conforme al proceso de gestión de incidentes del SGSI. El riesgo residual post-explotación incluye la persistencia del atacante en caso de haber obtenido credenciales válidas o de haber logrado ejecutar código arbitrario mediante técnicas avanzadas (INTO OUTFILE, UDF injection, RCE).

6. Recomendaciones

Las siguientes recomendaciones se estructuran en tres planos — técnico, organizativo y de monitoreo — alineados con los controles del Anexo A de la norma ISO/IEC 27001:2022. Cada recomendación incluye su control asociado para facilitar la trazabilidad con el SGSI.

6.1 Controles técnicos a nivel de aplicación

- Implementar consultas parametrizadas (prepared statements) mediante PDO o mysqli_prepare en todas las operaciones contra la base de datos, eliminando la concatenación directa de entradas del usuario. [Control A.8.25 — Ciclo de vida de desarrollo seguro]
- Aplicar validación estricta de entradas en el servidor mediante listas blancas (whitelisting) de caracteres y tipos de dato permitidos por campo. [Control A.8.26 — Requisitos de seguridad de las aplicaciones]
- Escapar adecuadamente las salidas renderizadas para prevenir vulnerabilidades colaterales como XSS (cross-site scripting). [Control A.8.28 — Codificación segura]
- Aplicar el principio de mínimo privilegio a los usuarios de base de datos utilizados por la aplicación, eliminando privilegios innecesarios como FILE, SUPER o GRANT. [Control A.8.2 — Derechos de acceso privilegiados]
- Deshabilitar la exposición de mensajes de error detallados en producción, utilizando páginas de error genéricas que no revelen información del stack o de la base de datos.

6.2 Controles perimetrales y de infraestructura

- Desplegar un Web Application Firewall (WAF) — soluciones como ModSecurity con el ruleset OWASP CRS — capaz de detectar y bloquear patrones comunes de inyección SQL. [Control A.8.23 — Filtrado web]
- Configurar reglas de iptables o nftables para limitar el rate de peticiones HTTP y mitigar intentos de fuzzing automatizado.

- Forzar el uso exclusivo de HTTPS con TLS 1.2 o superior y configurar cabeceras de seguridad HTTP (HSTS, CSP, X-Frame-Options, X-Content-Type-Options).
- Segmentar la red de forma que la base de datos no sea accesible directamente desde la red pública, restringiendo el acceso mediante firewalling interno. [Control A.8.22 — Segregación de redes]

6.3 Controles organizativos y de proceso

- Incorporar revisiones de código seguras (secure code review) en el flujo de desarrollo, con apoyo de herramientas SAST (análisis estático) como SonarQube o Semgrep. [Control A.8.25]
- Ejecutar pruebas DAST (análisis dinámico) de forma periódica con herramientas como OWASP ZAP o Burp Suite Professional sobre los entornos de pre-producción.
- Realizar pruebas de penetración (pentesting) anuales ejecutadas por equipos independientes, con emisión de informes formales y seguimiento del plan de remediación. [Control A.8.29 — Pruebas de seguridad en desarrollo y aceptación]
- Impartir formación y concientización periódica en desarrollo seguro y OWASP Top 10 al equipo de desarrollo. [Control A.6.3 — Concientización, educación y formación]
- Mantener y actualizar de forma periódica el procedimiento de gestión de incidentes, incluyendo plantillas de informe como la utilizada en este documento. [Controles A.5.24 a A.5.28]

6.4 Controles de monitoreo y detección

- Centralizar los logs de Apache, MariaDB y la aplicación en un SIEM (Wazuh, Graylog, Splunk o equivalente) con reglas de correlación orientadas a detectar patrones de inyección SQL. [Control A.8.15 — Registro de eventos]
- Configurar alertas en tiempo real sobre peticiones sospechosas (presencia de comillas simples, palabras clave SQL, operadores booleanos anómalos) en los parámetros HTTP.
- Habilitar la auditoría nativa de MariaDB (plugin server_audit) para registrar consultas sensibles y accesos privilegiados. [Control A.8.16 — Monitoreo de actividades]
- Revisar periódicamente los registros de acceso y establecer métricas clave (KPI / KRI) de seguridad para su reporte a la alta dirección.

7. Conclusión

El ejercicio de simulación documentado en este informe ha permitido evidenciar, de forma práctica y controlada, la facilidad con la que una vulnerabilidad de inyección SQL puede ser explotada cuando una aplicación web carece de los controles de seguridad más elementales: validación de entradas, uso de consultas parametrizadas y aplicación del principio de mínimo privilegio en el acceso a la base de datos. Con una única carga útil de doce caracteres (1' OR '1'='1) se logró extraer la totalidad de los registros de la tabla de usuarios, comprometiendo de forma integral la confidencialidad de la información almacenada.

La vulnerabilidad de inyección SQL, a pesar de ser conocida y documentada desde hace más de dos décadas, continúa siendo una de las amenazas más frecuentes y con mayor impacto en aplicaciones web, tal como reflejan los informes anuales de OWASP, MITRE y Verizon DBIR. Su prevalencia evidencia que las barreras para su mitigación no son de naturaleza técnica —las contramedidas son bien conocidas y maduras— sino fundamentalmente organizativas: requieren de procesos formales de desarrollo seguro, revisión continua del código, formación del personal y una cultura organizacional de seguridad orientada al ciclo de vida completo del software.

Desde la perspectiva del Sistema de Gestión de Seguridad de la Información (SGSI), este incidente simulado confirma la relevancia de implementar y mantener de forma efectiva los controles del Anexo A de la norma ISO/IEC 27001:2022 relacionados con la seguridad en el desarrollo (A.8.25, A.8.26, A.8.28, A.8.29), la gestión de accesos (A.8.2), la segmentación de redes (A.8.22), el monitoreo continuo (A.8.15, A.8.16) y la gestión estructurada de incidentes (A.5.24 a A.5.28). La ausencia o debilidad de cualquiera de ellos configura un riesgo material que debe ser identificado, evaluado y tratado conforme al proceso formal de gestión del riesgo del SGSI.

Como lección aprendida del ejercicio, se recomienda incorporar este caso de estudio al programa anual de concientización en ciberseguridad y al material formativo del equipo de desarrollo, asegurando que el conocimiento obtenido se traduzca en mejoras concretas, medibles y verificables del nivel de madurez del SGSI de la organización.

Finalmente, se deja constancia de que el presente informe se elabora con fines formativos y de simulación. La totalidad de las acciones descritas se han ejecutado en un entorno virtualizado de laboratorio aislado, sin afectación a sistemas productivos, datos reales ni a terceros, cumpliendo en todo momento los principios éticos y legales aplicables al ejercicio profesional de la ciberseguridad.